

RAPPORT TECHNIQUE

# Cyberattaque LockBit 3.0

CHRCE — Corbeil-sur-Essonne

Nuit du 20 au 21 août 2022

---

Clément HERBRECHT-BOURGOIN · Chef de projet

Bohdan DYSHLEVYY · Analyste forensique

Romain RETIERE · Spécialiste PCA

Nicolas TOURNES · Spécialiste PRA





# CyberShield

Conseil & Réponse à Incident

Fondée en 2018 — Paris, France  
CERT qualifié ANSSI PRIS  
47 collaborateurs — 8 pôles d'expertise

## Équipe mandatée sur ce dossier

- Clément HERBRECHT-BOURGOIN — Chef de mission
- Bohdan DYSHLEVYY — Analyste forensique
- Romain RETIERE — Spécialiste PCA / Conformité
- Nicolas TOURNES — Spécialiste PRA / Remédiation

## Qui sommes-nous ?

CyberShield accompagne les organisations publiques et privées face aux cybermenaces : réponse à incident, audit, reconstruction post-attaque et mise en conformité réglementaire (RGPD, NIS2, PGSSI-S).

**120+**

incidents traités  
depuis 2018

**98%**

clients recommandent  
nos services

**< 4h**

temps de réponse  
moyenne (MTTR)

## Références & Missions notables

### CH Métropole Nord (2023)

Réponse à incident ransomware — reconstruction SI complet en 18 jours

### Conseil Régional Île-de-France (2023)

Audit ANSSI post-intrusion — plan de remédiation 24 mois

### Opérateur énergie OIV (2022)

Cellule de crise NIS2 — notification ANSSI — investigation forensique

### Groupe bancaire (2022)

Réponse incident BEC + exfiltration — confinement en moins de 2h

### Université Paris-Saclay (2021)

Reconstruction post-ransomware — PRA — formation équipes DSI

# Contexte de l'incident

Chef de projet — Clément HERBRECHT-BOURGOIN

---

## Le CHRCE

1 068 lits · 700 000 habitants · Île-de-France  
Urgences adultes, pédiatriques, SAMU, 50 spécialités

**LockBit 3.0**

Famille ransomware

**10 jours**

Présence silencieuse

**90%**

SI chiffré

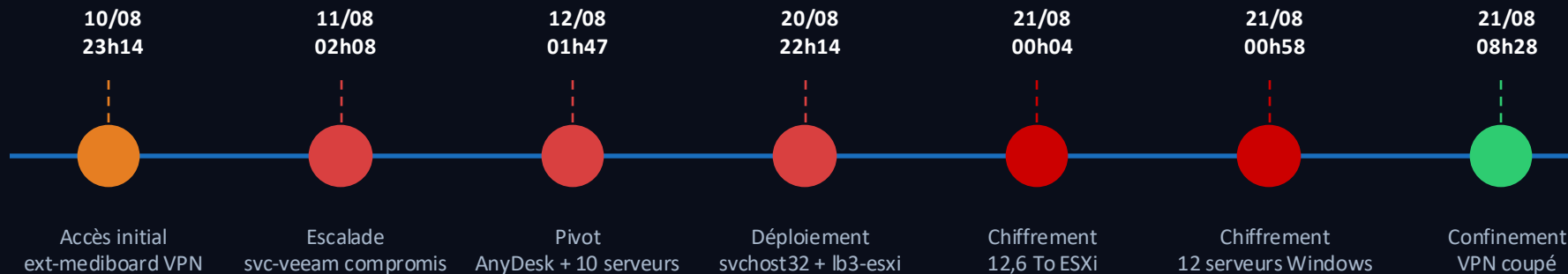
**12,6 To**

Données chiffrées

*Double extorsion : données volées AVANT chiffrement · Rançon 10 M\$ · Non-paiement décidé · 11 Go publiés par LockBit fin septembre 2022*

# Chronologie de l'attaque

10 jours de présence silencieuse — déclenchement en 1h44



MTTD (Mean Time To Detect) : 10 jours, 2h16  
Aucune alerte durant 10 jours — détection humaine sur panne visible

MTTR (confinement) : 7h46 après déclenchement  
Alerte FortiGate 01h00 ignorée 6h46 — aucune astreinte sécurité

# Chaîne d'attaque — 5 phases ANSSI

Analyste forensique – Bohdan DYSHLEVYY

## Phase 1

### Accès initial

ext-mediboard VPN  
AWS 18.184.32.247  
host-check BYPASSED

#### MITRE

T1078.004  
T1190

## Phase 2

### Reconnaissance & Exfiltration

Énumération AD  
47 GPO listés  
113 Mo → Mega.nz

#### MITRE

T1069  
T1567.002

## Phase 3

### Escalade & Pivot

svc-veeam compromis  
5 SePrivileges  
AnyDesk service

#### MITRE

T1078.002  
T1219

## Phase 4

### Déploiement malware

svchost32.exe × 12  
lb3-esxi.elf × 2  
WinUpdate\_Svc

#### MITRE

T1053.005  
T1105

## Phase 5

### Action finale (Chiffrement)

52 VMDKs / 12,6 To  
148 VMs, 78 sauvegardes  
12 serveurs Windows  
README\_LB3.txt

#### MITRE

T1486  
T1491

# Timeline forensique — Événements clés

Extraits des logs VPN, DC01, FortiGate, ESXi, Veeam

|       |         |              |                                                                                     |
|-------|---------|--------------|-------------------------------------------------------------------------------------|
| 10/08 | 23h14   | VPN          | ext-mediboard depuis 18.184.32.247 (AWS) — host-check=BYPASSED                      |
| 11/08 | 02h08   | DC01 4624    | svc-veeam compromis — SeBackupPrivilege + SeDebugPrivilege attribués                |
| 12/08 | 01h47   | DC01 4624    | LogonType 10 → SIH-APP-01 — AnyDesk_Service installé en service Windows             |
| 20/08 | 02h-06h | Squid        | 11 POST g.api.mega.co.nz — sources .20/.30/.55/.56 — ~113 Mo exfiltrés              |
| 20/08 | 22h14   | FW logid 144 | SMB C\$ × 12 serveurs — dépôt svchost32.exe (MD5: a56b0d8e...)                      |
| 20/08 | 22h04*  | ESXi shell   | SSH root — upload lb3-esxi.elf (MD5: f8c3a6b0...) — extinction 11 VMs               |
| 21/08 | 00h04*  | ESXi shell   | lb3-esxi.elf lancé — 52 VMDKs / 12,6 To chiffrés en 1h44, 148 VMs et 78 sauvegardes |
| 21/08 | 00h58   | Sched.Task   | WinUpdate_Svc déclenché — svchost32.exe SYSTEM sur 12 machines                      |
| 21/08 | 01h00   | FW logid 250 | ⚠ ALERTE : 'svchost32.exe spawned on 12 hosts simultaneously' — ignorée 6h46        |
| 21/08 | 08h28   | VPN          | Realm Prestataires désactivé — 62 sessions coupées — fin incident actif             |

\* Heures UTC converties en heure locale (+2h)

# Indicateurs de compromission & MITRE ATT&CK

IoC exploitables immédiatement — 30 techniques identifiées

## IoC — Indicateurs de compromission

|                      |                                                                                                    |
|----------------------|----------------------------------------------------------------------------------------------------|
| <b>IPs attaquant</b> | <b>18.184.32.247 / 18.185.11.92 / 3.121.44.18</b><br>AWS eu-central-1 — sessions VPN ext-mediboard |
| <b>IP interne</b>    | <b>10.9.8.14</b><br>Attribution VPN ext-mediboard — source de toutes les actions                   |
| <b>Exfiltration</b>  | <b>g.api.mega.co.nz</b><br>31.216.148.34 / 31.216.148.35 — 113 Mo exfiltrés                        |
| <b>Hash Windows</b>  | <b>MD5 : a56b0d8e3f4c7b1a...</b><br>svchost32.exe — ransomware LockBit 3.0 Windows                 |
| <b>Hash ESXi</b>     | <b>MD5 : f8c3a6b0e1f4d7c2...</b><br>lb3-esxi.elf — ransomware LockBit 3.0 ESXi                     |
| <b>Tâche planif.</b> | <b>WinUpdate_Svc</b><br>svchost32.exe -pass Xk9#mLp2 -threads 16 -net true                         |
| <b>Backdoor</b>      | <b>AnyDesk_Service</b><br>C:\ProgramData\AnyDesk.exe — service persistant SIH-APP-01               |
| <b>Rançon</b>        | <b>README_LB3.txt</b><br>support@lockbit3-decryptor.onion — 10 M\$                                 |

## Top MITRE ATT&CK — 30 techniques

|                    |                                                               |
|--------------------|---------------------------------------------------------------|
| <b>T1190</b>       | T1190 Exploit Public-Facing Application / accès VPN compromis |
| <b>T1078.004</b>   | Valid Accounts: Cloud (ext-mediboard)                         |
| <b>T1078.002</b>   | Valid Accounts: Domain (svc-veeam)                            |
| <b>T1110.003</b>   | Brute Force: Password Spraying                                |
| <b>T1021.001-4</b> | Lateral Movement (RDP / SMB / SSH)                            |
| <b>T1219</b>       | Remote Access Software (AnyDesk)                              |
| <b>T1567.002</b>   | Exfiltration to Cloud Storage (Mega.nz)                       |
| <b>T1053.005</b>   | Scheduled Task — WinUpdate_Svc                                |
| <b>T1486</b>       | Data Encrypted for Impact (12,6 To)                           |
| <b>T1070.001</b>   | Clear Windows Event Logs (EventID 1102)                       |

# Systemes impactés — Bilan post-attaque

Spécialiste PCA — Romain RETIERE

## DC01/02/03

COMPROMIS + CHIFFRÉ

AD inutilisable — logs effacés

## SIH-APP/DB

CHIFFRÉ

Mediboard 480 Go — admissions HS

## PHARMA / LABO

CHIFFRÉ

Pharmacie + labo HS

## ESX-PROD 1-5

CHIFFRÉ

5 ESXi — 100% VMs HS

## BACKUP-SRV

À VÉRIFIER

SSH contacté — inspecter

## DPI-APP/DB

CHIFFRÉ

Dossiers patients 1,2 To — HS

## PACS-01

CHIFFRÉ

Imagerie 8 To — radio impossible

## MAIL + FILE

CHIFFRÉ

Exchange + DFS — comm. HS

## NAS-BACKUP

COMPROMIS

78/78 fichiers .lockbit3

## BANDES (19/08)

HORS LIGNE ✓

Seule source saine

# Actions immédiates en réponse à l'incident (0–72h)

Cellule de crise — Contention — Investigation — Obligations

## Cellule de crise

- RSSI — pilotage technique
- DSI — PCA/PRA
- DPO — CNIL 72h
- Direction — communication
- Juriste — plainte
- CERT ANSSI PRIS — forensique

## Actions prioritaires

- DENY-ALL VPN → PROD appliqué
- Realm Prestataires désactivé — 62 sessions
- Désactiver ext-mediboard + svc-veeam dans AD
- Bloquer IPs AWS + Mega.nz sur FW + proxy
- Supprimer tâche WinUpdate\_Svc
- Supprimer AnyDesk de SIH-APP-01
- Collecter RAM + logs réseau + images disque
- Tester bandes LIB-BANDES-01 sur infra isolée
- Notification CNIL Art.33 — avant 24/08 01h30

FAIT

FAIT

FAIT

FAIT

FAIT

FAIT

< 5h

< 48h

< 72h

# Impact métier & Plan de continuité (PCA)

Activation du mode dégradé



## Urgences / SAMU

Dossier papier urgence — ordonnances manuelles

**RTO: 30min-1h**



## Bloc opératoire

Fiche papier anesthésie — reports non urgents

**RTO: 30min-1h**



## Imagerie (PACS)

Report examens — transfert CH partenaire

**RTO: 5h**



## Pharmacie

Dispensation manuelle — registre papier

**RTO: 2h**



## Laboratoire

Résultats par téléphone / fax

**RTO: 5h**



## Admissions (SIH)

Registre papier — numérotation manuelle

**RTO: 12h**

# PCA : Organisation Technique

---

## Messagerie



## Bastion pour l'ICC



# Impact financier & Obligations RGPD

Analyse des coûts et calendrier réglementaire

## Impact financier

|                                                    |                 |                 |
|----------------------------------------------------|-----------------|-----------------|
| Coûts directs (CERT, matériel, licences)           | 260 k€          | 680 k€          |
| Pertes exploitation (activité, PMSI, mode dégradé) | 1 180 k€        | 4 130 k€        |
| Risques sanctions CNIL (données santé Art.9)       | 0 €             | 20 000 k€       |
| <b>TOTAL (hors sanction max)</b>                   | <b>1 440 k€</b> | <b>4 810 k€</b> |

## Obligations RGPD — Calendrier

**T0+24h → 22/08 01h30**

Alerte initiale ANSSI (NIS2)

**T0+72h → 24/08 01h30**

Notification CNIL — Art. 33 RGPD (données santé)

**T0+72h → 24/08 01h30**

Rapport complet ANSSI

**Immédiat**

Signalement ARS Île-de-France

**Sans délai**

Dépôt de plainte — BEFTI / C3N

**Variable**

Information patients si risque élevé (Art. 34)

# Vulnérabilités exploitées — 7 failles critiques

Spécialiste PRA — Nicolas TOURNES

---

1

## **CVE-2021-22893 — Pulse Secure 9.1R14**

CVSS 10.0 — RCE sans auth — Non patché 16 mois après publication

2

## **Absence de MFA sur le VPN**

Auth par mot de passe seul — 1 compte compromis → 180 serveurs accessibles

3

## **Règle pare-feu VPN → Production ANY/ANY**

policyid=3 sans restriction — propagation totale depuis 1 compte prestataire

4

## **svc-veeam surprivilégié**

SeBackupPrivilege + SeDebugPrivilege + SeImpersonatePrivilege — Domain Admin de facto

5

## **SSH root ESXi accessible depuis VPN**

Accès direct aux VMDKs depuis réseau prestataires — chiffrement 12,6 To rendu possible

6

## **Sauvegardes connectées au réseau production**

NAS-BACKUP joignable depuis VLAN VPN — 78/78 fichiers .lockbit3 perdus

7

## **Absence de SIEM et d'EDR**

Aucune détection pendant 10 jours — alerte FortiGate 01h00 ignorée 6h46

# Plan de Reprise d'Activité (PRA) — Clean Rebuild

Reconstruction complète — RPO 19/08 23h58 — RTO par priorité

⚠ Clean Rebuild obligatoire — NE PAS restaurer sur systèmes compromis — Nouveau matériel recommandé

|    |                            |                     |              |
|----|----------------------------|---------------------|--------------|
| P1 | Nouveau AD (2 DCs)         | RTO : 4h            | J+7 (28/08)  |
| P1 | vCenter + ESXi propres     | RTO : 2h après AD   | J+7 (28/08)  |
| P1 | DPI-APP/DB — Crossway      | RTO : 1h après ESXi | J+10 (31/08) |
| P1 | Pharmacie — Pharma+        | RTO : 4h après ESXi | J+10 (31/08) |
| P2 | SIH + Labo + Veeam         | RTO : 4h            | J+14 (04/09) |
| P2 | Exchange 2019              | RTO : 8h            | J+14 (04/09) |
| P3 | PACS (8 To) + RH + Finance | RTO : Délai long    | J+42 (02/10) |

Seule source de restauration saine : bandes LIB-BANDES-01 (éjectées 19/08 23h58) — Tester sur infra isolée AVANT production

# Plan d'amélioration — Court, moyen, long terme

De 0 à 24 mois — investissement vs coût de l'incident

| Court terme<br>0–3 mois                                                                                                                                                                                                                                                                                               | Moyen terme<br>3–12 mois                                                                                                                                                                                                                                                                                           | Long terme<br>12–24 mois                                                                                                                                                                                                                                                                             |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <ul style="list-style-type: none"><li>✓ MFA sur TOUS les accès distants</li><li>✓ Remplacer Pulse Secure 9.1R14</li><li>✓ Segmentation VLAN VPN→Prod</li><li>✓ EDR sur tous les serveurs</li><li>✓ Sauvegardes hors ligne (3-2-1-1-0)</li><li>✓ SIEM + astreinte RSSI 24/7</li></ul> <p><b>Budget : 70–170 k€</b></p> | <ul style="list-style-type: none"><li>✓ PAM — rotation comptes à privilèges</li><li>✓ Bastion d'accès sécurisé</li><li>✓ Zero Trust Network Access</li><li>✓ Gestion vulnérabilités (Tenable)</li><li>✓ Audit externe + pentest</li><li>✓ Exercice tabletop semestriel</li></ul> <p><b>Budget : 165–465 k€</b></p> | <ul style="list-style-type: none"><li>✓ Certification ISO 27001</li><li>✓ Architecture Zero Trust complète</li><li>✓ CSIRT interne ou CSIRT Santé</li><li>✓ PSSI conforme PGSSI-S</li><li>✓ Red Team annuel</li><li>✓ Sensibilisation annuelle personnel</li></ul> <p><b>Budget : 230–515 k€</b></p> |
| <p><b>ROI : Total 24 mois 465 k€ → 1,15 M€ vs Coût de cet incident : 1,4 M€ → 4,8 M€ → Ratio 1:3 à 1:5</b></p>                                                                                                                                                                                                        |                                                                                                                                                                                                                                                                                                                    |                                                                                                                                                                                                                                                                                                      |

# Conclusion & Retour d'expérience (RETEX)

## 5 enseignements fondamentaux

---

### UN COMPTE VPN SANS MFA = UNE PORTE OUVERTE AU SI ENTIER

1 compte ext-mediboard → 90% du SI chiffré

### SANS SIEM NI EDR, 10 JOURS D'ATTAQUE SONT INVISIBLES

Comportements anormaux non corrélés — MTTD 10 jours

### UNE RÈGLE PARE-FEU TROP LARGE = PROPAGATION TOTALE

ANY/ANY → 180 serveurs accessibles depuis 1 compte VPN

### SAUVEGARDES CONNECTÉES = SAUVEGARDES PERDUES

78/78 fichiers .lockbit3 — règle 3-2-1-1-0 vitale

### UNE ALERTE SANS DESTINATAIRE EST UNE ALERTE INUTILE

FortiGate 01h00 ignorée 6h46 — astreinte 24/7 obligatoire

# Questions ?

Rapport technique disponible — 3 documents · 56 pages

Clément HERBRECHT-BOURGOIN · Bohdan DYSHLEVYY · Romain RETIERE · Nicolas TOURNES

BUT Informatique · Cybersécurité · SAE Réponse à incident

# Top 10 — Recommandations de sécurité

Mesures qui auraient changé l'issue de l'attaque

- |    |                                                             |                           |
|----|-------------------------------------------------------------|---------------------------|
| 1  | MFA sur TOUS les accès distants sans exception              | Empêche l'accès initial   |
| 2  | Segmentation VLAN VPN → Production (whitelist)              | Bloque la propagation     |
| 3  | Sauvegardes hors ligne immuables — règle 3-2-1-1-0          | Protège la restauration   |
| 4  | EDR comportemental sur tous serveurs et postes              | Détection précoce         |
| 5  | SIEM temps réel + astreinte RSSI 24/7                       | MTTD 10j → <1h            |
| 6  | Moindre privilège — supprimer SeDebugPrivilege des services | Bloque l'escalade         |
| 7  | Désactiver SSH root ESXi — VLAN admin dédié                 | Protège la virtualisation |
| 8  | Comptes prestataires temporaires + MFA + restriction IP     | Réduit la surface         |
| 9  | Isoler sauvegardes sur VLAN dédié — push uniquement         | Empêche .lockbit3         |
| 10 | Plan de réponse à incident formalisé + exercice annuel      | MTTR 7h46 → <1h           |